

Zoom Breakout Automator Security Evidence

This folder contains supporting evidence for Zoom Marketplace review and beta sharing requests.

Documents included:

- ssdlc.md
- sast-dast-report.md
- privacy-policy-evidence.md
- security-policy.md
- incident-response-policy.md
- vulnerability-management.md
- infrastructure-dependency-management.md
- data-retention-protection-policy.md

The app is a static Zoom App using HTML, CSS, JavaScript, the Zoom Apps SDK, Cloudflare Worker static hosting, and local browser storage.

Secure Software Development Lifecycle Evidence

App: Zoom Breakout Automator

Last updated: September 7, 2026

Scope

Zoom Breakout Automator is a small static Zoom App for meeting hosts and co-hosts. It manages breakout room presets and sends breakout room actions through the Zoom Apps SDK.

The app has no backend server, no external database, and no custom authentication system. Room presets are stored locally in the user's browser storage.

Development Process

- Requirements are defined before implementation.
- Requested Zoom scopes and SDK capabilities are limited to the app's core breakout room functionality.
- Code changes are reviewed manually before deployment.
- JavaScript syntax checks are run before deployment.
- Security-relevant files are reviewed before publishing, including app.js, src/worker.js, wrangler.jsonc, _headers, and privacy/support pages.
- Production deployments are made through GitHub and Cloudflare Workers.

Security Controls

- HTTPS-only hosting through Cloudflare Workers.
- Worker-level TLS guard rejects requests below TLS 1.2 when TLS metadata is available.
- Security headers are applied by the Worker response handler.
- Content Security Policy limits script loading to the app origin and the Zoom Apps SDK CDN.
- No Zoom OAuth tokens are stored by the app.
- No Zoom user, meeting, participant, or preset data is stored on an external server.
- Room presets are stored locally on the user's device.

Change Management

Changes are committed to the GitHub repository and deployed through Cloudflare. The app is tested locally in browser demo mode and then inside Zoom Meetings before external release.

Review Criteria

Before deployment, the following checks are performed:

- JavaScript syntax check.
- Manual review for hardcoded secrets.
- Manual review for unexpected external network endpoints.
- Manual review of requested Zoom scopes and SDK capabilities.
- Verification that privacy, terms, support, and documentation URLs are reachable.

SAST And DAST Evidence Report

App: Zoom Breakout Automator

Last updated: September 7, 2026

Summary

This report documents lightweight static and dynamic security checks for the Zoom Breakout Automator beta submission.

The app is a static HTML/CSS/JavaScript Zoom App. It has no backend server, no database, no server-side sessions, and no server-side storage of Zoom user data or OAuth tokens.

SAST Scope

Files reviewed:

- app.js
- src/worker.js
- index.html
- privacy.html
- terms.html
- support.html
- documentation.html
- wrangler.jsonc
- _headers

Checks performed:

- JavaScript syntax check with Node.js.
- Custom local static security check with npm run security:check.
- Manual static review for hardcoded secrets, access tokens, private keys, and client secrets.
- Manual static review for unexpected external network endpoints.
- Manual static review of Content Security Policy and security headers.
- Manual review of local storage usage.

Result:

- No hardcoded Zoom client secrets or OAuth tokens found.
- No external database or backend endpoint found.
- Local storage is used only for user-entered room presets.
- External script loading is limited to the Zoom Apps SDK CDN.
- The custom security check passed on September 7, 2026.

Command output:

Security check passed.

Files scanned: 9

No hardcoded secrets detected.

No unexpected external URLs detected.

TLS 1.2+ guard and security headers are present in src/worker.js.

DAST Scope

Checks performed against the deployed Cloudflare URL:

- HTTPS URL is used for the application.
- The Worker is configured to reject TLS versions below TLS 1.2 when Cloudflare TLS metadata is available.
- Security headers are applied at the Worker layer:
 - Strict-Transport-Security
 - X-Content-Type-Options
 - Content-Security-Policy
 - Referrer-Policy

Limitations

This is a lightweight review for a small static beta app. It is not a third-party penetration test and does not claim SOC 2, ISO 27001, or other formal certification.

Current Status

The app is considered suitable for controlled testing once the latest GitHub changes are deployed to Cloudflare and the hosted URL is verified.

Privacy Policy Evidence

App: Zoom Breakout Automator

Last updated: September 7, 2026

Public Privacy Policy URL

The app's Privacy Policy is published at:

<https://zoombreakoutautomator.graffuxxx.workers.dev/privacy.html>

Privacy Summary

The Privacy Policy explains that Zoom Breakout Automator:

- Does not sell personal information.
- Does not operate an external backend server.
- Does not store Zoom user data, meeting data, participant data, or OAuth tokens on an external server.
- Stores room presets locally in the user's browser storage only.
- Provides information about user data rights and how to contact the developer.

Data Subject Rights

The policy informs users that, depending on location, they may have rights to access, correct, delete, restrict, or object to the processing of personal information. Because the app does not store user data on an external server, users can remove locally stored app data by clearing local browser/app storage or removing the app from Zoom.

Security Policy

App: Zoom Breakout Automator

Last updated: September 7, 2026

Security Contact

Security issues should be reported through the support contact listed on the Zoom Marketplace app listing.

Data Handling

The app does not store Zoom user data, meeting data, participant data, room data, or OAuth tokens on an external server. Room presets entered by users are stored locally in browser storage on the user's device.

Hosting

The app is hosted on Cloudflare Workers as static files. HTTPS is required. Requests below TLS 1.2 are rejected by the Worker when Cloudflare TLS metadata is available.

Access Control

The app uses Zoom Apps SDK capabilities available to the authorized Zoom user in the active meeting. Breakout room controls are expected to work only for hosts and co-hosts where Zoom permits those actions.

Secrets

Zoom client secrets and production credentials must not be stored in the public repository or client-side source code. The current app does not require client secrets in runtime code.

Dependencies

The app uses no production npm package dependencies. The Zoom Apps SDK is loaded from Zoom's official SDK CDN.

Incident Management And Response Policy

App: Zoom Breakout Automator

Last updated: September 7, 2026

Purpose

This policy describes how security or privacy incidents are handled for Zoom Breakout Automator.

Incident Types

Relevant incidents may include:

- Accidental exposure of credentials.
- A vulnerability in the app code or deployment configuration.
- Unexpected storage or transmission of user data.
- Abuse of the app's Zoom permissions.

Response Process

- Triage the report and determine severity.
- Disable or roll back the affected deployment if needed.
- Remove exposed credentials and rotate them where applicable.
- Patch the affected source files.
- Deploy the fix through Cloudflare.
- Notify affected users or Zoom Marketplace reviewers when required.
- Document the root cause and prevention steps.

Data Breach Considerations

The app does not maintain an external database or backend user store. If an incident affects local user data, users will be advised to remove the app and clear local app/browser storage.

Contact

Users and reviewers can contact the developer through the support contact listed on the Zoom Marketplace app listing.

Vulnerability Management Procedures

App: Zoom Breakout Automator

Last updated: September 7, 2026

Identification

Vulnerabilities may be identified through manual code review, user reports, Zoom Marketplace review feedback, browser testing, and dependency checks.

Assessment

Each issue is assessed based on:

- Whether Zoom user data or meeting data could be exposed.
- Whether unauthorized users could trigger breakout room actions.
- Whether the app could load unexpected external scripts.
- Whether the deployment weakens HTTPS or required security headers.

Remediation

Critical fixes are prioritized immediately. Lower-risk issues are fixed before the next release. Changes are deployed through GitHub and Cloudflare Workers.

Verification

After remediation:

- JavaScript syntax checks are rerun.
- Security headers are checked again.
- The app is retested in a Zoom Meeting when functionality is affected.

Disclosure

If a vulnerability affects Zoom users, the developer will notify affected users and Zoom Marketplace reviewers when appropriate.

Infrastructure And Dependency Management Policy

App: Zoom Breakout Automator

Last updated: September 7, 2026

Infrastructure

The app is hosted as static files on Cloudflare Workers. The application does not use a custom backend server, database, message queue, object storage bucket, or server-side account system.

Deployment

Source files are stored in GitHub and deployed to Cloudflare. The deployed Worker serves the app over HTTPS and applies security headers to responses.

Dependencies

The app has no production npm dependencies. It uses:

- HTML
- CSS
- JavaScript
- Zoom Apps SDK from Zoom's official CDN
- Cloudflare Workers static asset hosting

Dependency Review

Because the production app has no bundled third-party package dependencies, dependency risk is low. If dependencies are added later, they should be reviewed for maintenance status, license, necessity, and known vulnerabilities before deployment.

Configuration Review

Security-relevant deployment configuration includes:

- wrangler.jsonc
- .assetsignore
- src/worker.js
- _headers

These files should be reviewed before publishing or sharing the app externally.

Data Retention And Protection Policy

App: Zoom Breakout Automator

Last updated: September 7, 2026

Data Stored By The App

The app stores user-entered breakout room presets locally in the user's browser storage. The app does not store Zoom user data, meeting data, participant data, OAuth tokens, or room presets on an external server.

Retention

Local room presets remain on the user's device until the user removes them, clears local app/browser storage, or removes the app.

Deletion

Users can remove locally stored room presets by clearing app/browser storage or removing the app from Zoom. Because no external server storage exists, there is no server-side user record to delete.

Protection

The app is served over HTTPS. Security headers are applied at the Cloudflare Worker layer. The Content Security Policy restricts script loading to the app origin and the Zoom Apps SDK CDN.

Third Parties

The app does not share stored room presets with third parties.